

Keamanan Informasi, Perlindungan Data & Kepatuhan Regulasi

Arsitektur Perlindungan Data Terintegrasi pada Sistem Informasi Audit Internal
Penerapan SMKP Minerba (Kepdirjen ESDM No. 185.K/37.04/DJB/2019)

APLIKASI TARGET

SMKP Minerba Internal Audit System

STANDAR ACUAN UTAMA

Kepdirjen ESDM 185.K & OWASP Standards

KLASIFIKASI DOKUMEN

Confidential / Client Presentation

PENYUSUN DOKUMEN

Solution Architect & Security Advisory Team

1. Ringkasan Eksekutif (Executive Summary)

Penerapan **Sistem Manajemen Keselamatan Pertambangan (SMKP) Minerba** merupakan mandat regulasi mutlak bagi perusahaan pertambangan dan kontraktor jasa pertambangan di Indonesia. Proses audit internal menghasilkan data yang sangat sensitif, mencakup tingkat kepatuhan keselamatan, identifikasi celah operasional (*hazard & non-conformance*), rubrik penilaian 7 elemen, hingga dokumen rencana perbaikan (PICA).

Komitmen Bisnis: Aplikasi ini dirancang dengan prinsip *Security-by-Design* dan *Defense-in-Depth* guna menjamin bahwa seluruh data hasil audit terproteksi dari akses ilegal, tidak dapat dimanipulasi, dan siap dipertanggungjawabkan saat audit eksternal dari Inspektur Tambang Kementerian ESDM.

 Kerahasiaan

Data audit dan temuan area hanya dapat diakses oleh pihak yang berwenang sesuai wilayah tanggung jawab kerjanya.

 Integritas

Setiap penilaian matriks, lampiran bukti fisik, dan pembobotan skor dilindungi mekanisme anti-manipulasi (*anti-tampering*).

 Akuntabilitas

Seluruh aktivitas krusial dicatat secara otomatis dalam jejak audit digital (*immutable audit trail*) yang transparan.

2. Arsitektur Pertahanan Berlapis (Defense-in-Depth)

Sistem menerapkan 4 tingkatan proteksi komprehensif untuk menangkal potensi ancaman siber dari berbagai vektor:

LAYER 1 **Perimeter & Transport Security**

Enkripsi komunikasi data melalui protokol HTTPS/TLS, Strict-Transport-Security (HSTS), serta proteksi Anti-Back-History cache browser untuk mencegah kebocoran sesi di perangkat bersama.

LAYER 2 **Traffic Filtering & Inbound Guard**

Mekanisme Rate Limiting adaptif pencegah brute force, sanitasi CORS ketat, serta Content Security Policy (CSP) berbasis token kriptografis dinamis (Nonce) penangkal eksekusi skrip ilegal.

LAYER 3 **Identity & Role-Based Access Control (RBAC)**

Segmentasi ketat antara Tim Auditor Internal SMKP (Lead Auditor) dengan Auditor Perusahaan/Auditee (PIC Area). Pencegahan kebocoran data lintas area (IDOR protection).

LAYER 4 **Data Integrity & Secure Storage**

Hashing password satu arah (Bcrypt), validasi ketat berkas lampiran temuan, penomoran laporan standar ESDM, dan pencatatan audit log otomatis tanpa mencatat data pribadi sensitif.

3. Lapisan Keamanan Aplikasi & Nilai Bisnis

3.1 Manajemen Identitas & Tata Kelola Hak Akses (Access Governance)

Sistem membagi hak akses secara terisolasi sesuai hierarki tata kelola audit internal modern:

Peran Pengguna	Cakupan Wewenang	Nilai Keamanan & Bisnis
Auditor Internal SMKP (Lead Auditor / Admin)	Pembuatan sesi audit, pengisian matriks penilaian 7 elemen, penetapan kategori temuan, finalisasi skor, & pengawasan global.	OVERSIGHT MANDIRI Menjamin independensi evaluasi dan integritas nilai standar SMKP.
Auditor Internal Perusahaan (Auditee / PIC Area Kerja)	Akses terbatas (*read-only*) rekapitulasi sesi areanya sendiri, serta pengisian akar masalah & bukti perbaikan PICA.	DATA CONTAINMENT Mencegah auditee mengakses/mengubah data audit dari unit kerja lain.

Proteksi Sesi Aktif: Saat status akun seorang pengguna dinonaktifkan oleh Administrator, sistem secara otomatis memutuskan seluruh sesi aktif yang bersangkutan dari server (*forced revocation*), memastikan akses terputus seketika.

3.2 Rekam Jejak Digital & Integritas Laporan (Audit Trail)



Jejak Penilaian Matriks

Merekam perubahan nilai per kriteria, alasan penetapan kategori (Kritikal/Mayor/Minor), waktu perubahan, dan identitas auditor penilai.



Penguncian Pasca-Finalisasi

Sesi yang telah difinalisasi akan dikunci statusnya menjadi *read-only*, mencegah pengubahan nilai retroaktif secara sepihak.

3.3 Mitigasi Ancaman Siber & Perlindungan Injeksi

- Proteksi SQL Injection:** Komunikasi basis data menggunakan *Parameterized Query* terisolasi tanpa perakitan perintah SQL manual.
- Proteksi Cross-Site Scripting (XSS):** Sanitasi karakter otomatis dan diproteksi header *Content Security Policy (CSP)* berbasis token Nonce kriptografis per-permintaan.
- Proteksi CSRF:** Seluruh mutasi data divalidasi dengan token kriptografis anti-pemalsuan unik.
- Sanitasi Unggahan:** Dokumen bukti perbaikan dan lampiran disaring ketat (PDF, PNG, JPG, maks 5MB) dan disimpan terenkripsi di luar direktori web publik.

4. Kepatuhan Regulasi & Standar Industri

Arsitektur keamanan dan alur operasional aplikasi ini dibangun untuk memenuhi standar tata kelola keselamatan pertambangan nasional dan kerangka kerja keamanan informasi internasional:

 1. Kepdirjen Mineral dan Batubara ESDM No. 185.K/37.04/DJB/2019

Sistem mengotomatisasi perhitungan bobot matematis untuk **7 Elemen SMKP Minerba** (Kebijakan, Perencanaan, Organisasi & Personel, Implementasi, Pemantauan, Dokumentasi, Tinjauan Manajemen), memastikan hasil evaluasi tingkat kepatuhan (0 - 100%) objektif, akurat, dan sesuai format baku resmi **TT-MGT-FRS-026B**.

 2. Standar OWASP Top 10 Application Security

Mengintegrasikan praktik terbaik keamanan perangkat lunak dunia: kontrol akses ketat (*Broken Access Control mitigation*), validasi kriptografi sandi (*Cryptographic Failures prevention*), isolasi input (*Injection prevention*), dan pembatasan laju permintaan (*Rate Limiting & Anti-Automation*).

 3. Kesiapan Menghadapi Audit Eksternal (Audit Readiness)

Dengan adanya rekaman riwayat perubahan (*audit trail*), penomoran laporan baku, dan penyimpanan bukti fisik terorganisir, manajemen dapat menyajikan bukti evaluasi kepatuhan secara instan kepada auditor sertifikasi maupun Inspektur Tambang.

Ringkasan Matriks Kepatuhan Keamanan Sistem

Domain Kepatuhan	Mekanisme Kontrol Sistem	Status Kesiapan
Perlindungan Akun	Password Hashing Bcrypt, Rate-limited Login, Session Invalidation	MEMENUHI SYARAT
Pencegahan Manipulasi Nilai	Sesi Finalisasi Terkunci, Role Barrier, Validasi Server-Side	MEMENUHI SYARAT
Keamanan Jaringan & Web	CSP Nonce, HSTS, X-Frame-Options DENY, No-Sniff Headers	MEMENUHI SYARAT
Pencegahan Kebocoran Data	Scoping Area Kerja User, Anti-Back History Cache Control	MEMENUHI SYARAT

5. Kesimpulan & Komitmen Keberlanjutan

Sistem Informasi Audit Internal SMKP Minerba tidak hanya menghadirkan efisiensi digital dalam pencatatan dan evaluasi kepatuhan keselamatan kerja tambang, namun juga memberikan **fondasi keamanan siber yang kokoh** bagi seluruh pemangku kepentingan (*stakeholders*).



Nilai Tambah bagi Manajemen

Mengeliminasi risiko kehilangan dokumen fisik, mencegah keterlambatan penyelesaian temuan kritis melalui monitoring PICA terpusat, dan memastikan skor SMKP valid tanpa sengketa data.



Pemeliharaan Berkelanjutan

Sistem didukung kebijakan pembaruan keamanan berkala, prosedur pencadangan data (*database backup*), dan pemantauan integritas sistem berkelanjutan.

Pernyataan Jaminan Solusi: Arsitektur sistem telah diuji melalui rangkaian verifikasi pengujian otomatis dan inspeksi keamanan menyeluruh. Sistem ini dinyatakan siap beroperasi pada lingkungan produksi (*Production Ready*) untuk mendukung operasional bisnis pertambangan yang aman, selamat, dan patuh regulasi.

Disiapkan & Diverifikasi Oleh:

Lead Solution Architect & Cybersecurity Consultant

Tim Solusi Teknologi & Keamanan Sistem
Sistem Informasi Audit SMKP Minerba

Diterima & Disetujui Oleh:

Perwakilan Manajemen / Komite Audit Klien

Divisi K3KP / Manajemen Risiko / IT Governance
Perusahaan Klien